

Stakeholder memorandum

TO: IT Manager, Stakeholders

FROM: Lautaro Trigo

DATE: 16th of February

SUBJECT: Internal IT Audit Findings and Recommendations

Dear Colleagues,

Please review the following information regarding the Botium Toys internal audit scope, goals, critical findings, summary and recommendations.

Scope:

- The audit covered the entire Botium Toys security program
- The physical assets, processes, and internal procedures of the headquarters were evaluated.
- User permissions were analyzed in critical systems such as accounting, firewalls, and SIEM.
- Endpoint and intrusion detection protocols were reviewed.
- Compliance with current regulations and hardware registration was verified.

Goals:

- Align trade policies with industry best practices.
- Strictly comply with the NIST Cybersecurity Framework (CSF).
- Implement the principle of least privilege in all credentials.
- Strengthen technical controls and establish clear policies through strategy manuals.
- Ensure compliance with legal requirements (such as GDPR and PCI DSS).

Critical findings (must be addressed immediately):

- **Risk score 8/10:** The lack of current controls represents a high security risk.
- **Regulatory non-compliance:** There is a high probability of fines for not complying with international standards (GDPR/PCI DSS) when handling foreign customer data.
- **Inadequate asset management:** There is no real control over what assets are held or what would happen if they are lost.
- **Lack of essential controls:** It is urgent to implement encryption for payments and disaster recovery plans.

Findings (should be addressed, but no immediate need):

- **Improve physical security (lighting, alarm signage).**
- **Establish a manual monitoring and maintenance program for legacy or obsolete systems.**
- **Review and update account management policies for ex-employees.**

Summary/Recommendations:

Botium Toys' current security posture presents significant vulnerabilities that jeopardize business continuity and the integrity of customer data. It is recommended to immediately adopt the NIST framework to structure our defenses. Implementing technical controls such as encryption and incident recovery plans is crucial to avoid financial losses and regulatory fines. Furthermore, to sustain this growth securely, hiring additional cybersecurity personnel specialized in managing these controls daily is fully justified. By following these recommendations, Botium Toys will not only comply with the law but also strengthen the trust of its international customers.